

TP Sécurité Logiciel (SQL Injection)

A. Les 6 aspects de la sécurité d'une application

La **sécurité logiciel** regroupe l'ensemble des moyens **techniques, organisationnels, humains et légaux** visant à **réduire l'exposition** d'une application ou d'un système aux menaces. Ces menaces peuvent être

- **Passives** : écoute ou copie illégale d'informations.
- **Actives** : altération des données ou perturbation du service.

Les 6 Piliers de la Sécurisation

- **Authentification** : Vérifier l'identité d'un utilisateur, d'un processus ou d'un appareil (via mot de passe, certificats, authentification multifactorielle, etc.).
- **Contrôle d'accès** : Déterminer si un utilisateur a les droits nécessaires pour accéder à une ressource ou fonctionnalité.
- **Intégrité des données** : Garantir que les informations ne sont ni modifiées ni altérées (hachage, signature numérique).
- **Confidentialité** : Protéger les données sensibles contre l'accès non autorisé grâce au chiffrement.
- **Non-répudiation** : Assurer qu'un émetteur ou un récepteur ne puisse nier l'envoi ou la réception d'un message (via certificats et signatures numériques).
- **Protection contre l'analyse du trafic** : Sécuriser les échanges en utilisant des protocoles comme SSL/TLS et HTTPS.

B. Le test d'intrusion sur le web

1. Qu'est-ce qu'un test d'intrusion ?

Un test d'intrusion, ou **pentest**, est un audit de sécurité offensive visant à identifier les vulnérabilités d'un système d'information dans un temps limité. L'objectif est de les corriger avant qu'un attaquant ne les exploite.

Pourquoi est-il essentiel ?

- Vérifie si un système est vulnérable.
- Montre comment les failles peuvent être découvertes et exploitées.
- Propose des recommandations pour renforcer la sécurité.

Les entreprises réalisent ces tests car :

- Les erreurs humaines sont inévitables (code, configuration, réseau).
- Les attaques évoluent constamment.
- Les cyberattaques sont fréquentes et ciblent les faiblesses des systèmes.

Les différentes approches de pentest

Il existe trois niveaux d'accès aux informations lors d'un test d'intrusion :

- **Boîte noire** : Le pentester agit comme un attaquant externe avec très peu d'informations.
- **Boîte grise** : Il simule un utilisateur malveillant avec des accès limités.
- **Boîte blanche** : Il a un accès complet (code source, architecture...) pour identifier un maximum de vulnérabilités.

Un **test d'intrusion** $\neq$ **audit de sécurité** :

- Le pentest détecte des failles techniques.
- L'audit de sécurité évalue aussi les processus organisationnels (sauvegardes, procédures...).

Différence avec Bug Bounty & Red Team

- **Bug Bounty** : Les chercheurs sont rémunérés par vulnérabilité trouvée.
- **Red Team** : Simule une attaque avancée pour tester la capacité de défense d'une organisation.
- **Pentest** : Mission cadrée dans le temps avec un périmètre défini.

2. la posture d'un pentester

Le terme "hacker" ne désigne pas nécessairement une personne malveillante ; il évoque plutôt une capacité à penser différemment. Un pentester cherche à comprendre et tester les limites d'un système en adoptant une approche exploratoire.

Les hackers sont classés en trois catégories :

- **White Hat** : agit légalement pour améliorer la sécurité.
- **Grey Hat** : bien intentionné mais adopte parfois des pratiques illégales.
- **Black Hat** : malveillant et cherche à compromettre les systèmes.

L'éthique est importante en pentesting. Il est interdit de divulguer publiquement une vulnérabilité trouvée lors d'un audit sans respecter la **responsible disclosure**, qui consiste à avertir d'abord l'éditeur. Certaines entreprises possèdent une **VDP (Vulnerability Disclosure Policy)** pour encadrer ces divulgations.

D'un point de vue légal, l'intrusion non autorisée dans un système d'information est passible de sanctions. Seuls les tests d'intrusion mandatés sont autorisés. Des organismes comme l'ANSSI définissent des référentiels de sécurité.

3. Environnement de test d'intrusion

Avant un test d'intrusion, il est essentiel de collecter un maximum d'informations sur la cible. L'analogie avec un braquage de banque montre l'importance de bien se préparer avant d'attaquer directement le système.

Utilisation de Google Dorks

Google peut être exploité pour identifier des vulnérabilités et récupérer des données sensibles via des requêtes précises, appelées **Google Dorks**. Cette technique, popularisée en 2005, permet d'affiner les recherches sans accéder à des données non indexées.

Le site **Exploit-DB** (en anglais) recense une liste de Google Dorks dans ce qu'ils appellent la **Google Hacking Database (GHDB)**.

C'est à utiliser avec précaution et sur un périmètre pour lequel vous êtes autorisé.

Recherche d'Informations avec l'OSINT

L'**Open Source Intelligence (OSINT)** est utilisée pour collecter des informations sans interagir directement avec la cible. Cela inclut :

- Identifier les employés et leurs emails
- Vérifier si leurs emails figurent dans des bases de données piratées
- Explorer des dépôts GitHub/GitLab pour d'éventuelles fuites
- Rechercher des discussions sur des forums spécialisés

Des outils comme **theHarvester** et **Recon-ng** facilitent cette collecte.

Deep Web et Dark Web

Certaines données ne sont pas indexées par Google (Deep Web), tandis que d'autres circulent sur le Dark Web. Accéder à ces sources peut être illégal et doit être clairement défini dans la prestation.

Resources

https://owasp.org/www-community/Vulnerability_Scanning_Tools

<https://www.hacksplaining.com/lessons/sql-injection>

<https://tryhackme.com/r/room/sqlilab>

https://www.w3schools.com/sql/sql_injection.asp